

FUNDAÇÕES DO FORTE

CYBERSECURITY COMEÇA AQUI!



3

LISTA DE FIGURAS

Figura 1 – Incidentes reportados ao CERT.br – janeiro a dezembro de 2022	7
Figura 2 – Tela do WannaCry	9
Figura 3 – Tela de recursos do Windows	10
Figura 4 – Tela de aviso do GOLDENEYE	11
Figura 5 – Técnicas de ataque	11
Figura 6 – Motivações de ataque	13
Figura 7 – Ataque aos sites do governo do Ceará pedem anulação de votos da região Nordeste	14
Figura 8 – Ataque DDoS derruba a internet	15

SUMÁRIO

CYBERSECURITY COMEÇA AQUI!	4
1 INTRODUÇÃO	4
2 O CONCEITO DE CYBERSECURITY	4
2.1 A crescente preocupação contra ataques cibernéticos	4
3 CYBERSECURITY E NEGÓCIOS	5
4 VETORES DE ATAQUES	11
5 MOTIVAÇÃO DOS ATAQUES E O ENQUADRAMENTO JURÍDICO	12
CONCLUSÃO.....	15
REFERÊNCIAS.....	17

CYBERSECURITY COMEÇA AQUI!

1 INTRODUÇÃO

Cybersecurity é o “carro-chefe” do curso de Defesa Cibernética. Mas como podemos conceituar o termo exatamente? O que faz parte da segurança cibernética? Observamos que, independentemente do ramo de atividade em que as empresas atuam, investir em segurança da informação é algo que deve ser feito por todas elas – caso contrário, elas podem até sofrer prejuízos que acabarão por tirá-las do mercado.

Abordamos de maneira superficial, inicialmente, os tipos de ataques e técnicas, a fim de detalhá-los com maior profundidade nos capítulos seguintes. Apresentamos também os vetores e os motivos dos atacantes, de forma a termos um panorama dos perigos cibernéticos para, em um segundo momento, saber como combatê-los.

Bem-vindo(a) ao fascinante mundo da segurança cibernética!

2 O CONCEITO DE CYBERSECURITY

2.1 A crescente preocupação contra ataques cibernéticos

Ao longo dos últimos anos, é notória a crescente preocupação expressada por diferentes especialistas em relação à necessidade de proteção de sistemas de Tecnologia da Informação e Comunicação (TIC) contra ataques cibernéticos. Eles podem ser definidos como tentativas deliberadas, por parte de pessoas não autorizadas, de obter acesso a esses sistemas, geralmente com o objetivo de “roubo”, destruição ou prática de outros tipos de ações danosas ou ilegais.

De acordo com Craigen, Diakun-Thibault e Purse (2014), *Cybersecurity* é um termo amplamente utilizado, com definições muito diversas, por vezes até subjetivas e pouco informativas. No entanto, dentre as definições que melhor representam a perspectiva de *Cybersecurity*, destacam-se:

1. *Cybersecurity* implica a **salvaguarda das redes de computadores e das informações nelas contidas contra intrusão, danos ou descontinuidades** (LEWIS, 2006).
2. *Cybersecurity* envolve a **redução do risco de ataques a softwares, computadores e redes**. Isso inclui ferramentas usadas para detectar invasões, contenção de vírus, bloqueio de acessos maliciosos, forçar autenticação, uso de criptografia e assim por diante.
3. *Cybersecurity* é um **conjunto de ferramentas, políticas, conceitos e salvaguardas de segurança, diretrizes, abordagens de gerenciamento de riscos, ações, treinamentos, melhores práticas, garantias e tecnologias que podem ser usados para proteger o ambiente cibernético**, a organização e os recursos do usuário.

Assim sendo, pode-se concluir que o conceito *Cybersecurity* é mais abrangente do que apenas soluções tecnológicas, englobando também gestão, gerenciamento de riscos e continuidade de negócio, entre outros aspectos.

3 CYBERSECURITY E NEGÓCIOS

Em 2021, a empresa de cibersegurança Norton realizou um levantamento em 2021 que 58% dos brasileiros foram vítimas de um crime cibernéticos. A pesquisa aponta que 71 milhões de brasileiros sofreram ataques cibernéticos durante o ano de 2021 e que mais de 828 milhões de horas foram gastas (uma média de 11,6 horas por pessoa) tentando resolver os problemas.

Ainda segundo esse levantamento, o prejuízo total para o país, causado por esse tipo de prática 32 bilhões de reais (PANCINI, 2022). Enquanto alguns choram, outros vendem lenços: se por um lado, os ataques cibernéticos são sinônimo de prejuízos para a maioria das empresas, por outro lado podem representar uma grande oportunidade para empresas que sejam especializadas em segurança. A Tempest, empresa que surgiu no Recife em 2004, possui como clientes os principais bancos do país, além de empresas de comunicação como The Economist, The Guardian e a BBC, na Inglaterra. Apesar da grande concorrência das gigantes IBM, Symantec, HP e consultorias como a PwC e a Deloitte, em 2017 a Tempest possuía uma previsão de faturamento de 25 milhões de reais (SORIMA, 2017).

O crescimento de ocorrências de ataques cibernéticos se traduziu em um aumento nos investimentos para a sua prevenção. Em 2023, a empresa Gartner estimou que os gastos com segurança cibernética devem atingir a marca de US\$ 215 bilhões em 2024, o que representa um aumento de 14,3% em relação a 2023, quando foi gasto em torno de US\$ 188,1 bilhões (Brasil, País Digital, 2023).

É interessante observar em quais áreas especificamente esses novos investimentos estão indo: pesquisas indicam que *malware* e *phishing* são os ataques mais frequentes na América Latina, resultando em um prejuízo de 90 milhões de dólares por ano a bancos mexicanos. Boa parte dos investimentos têm sido realizados em segurança de dispositivos móveis, considerados mais do que nunca uma ferramenta profissional nas grandes corporações (IT FORUM 365, 2018; STEFANINI, 2019).

O CERT.br é o Grupo de Resposta a Incidentes de Segurança para a internet brasileira, mantido pelo NIC.br, do Comitê Gestor da Internet no Brasil, tendo sob sua responsabilidade o tratamento dos incidentes de segurança em computadores que envolvam redes conectadas à internet brasileira. Atua, ainda, como ponto central para notificações de incidentes de segurança no Brasil, provendo a coordenação e o apoio no processo de resposta a incidentes e, quando necessário, colocando as partes envolvidas em contato.

As estatísticas produzidas pelo CERT.br são fontes de informação confiáveis e atualizadas, podendo servir às empresas na forma de ferramentas auxiliares na identificação das principais ameaças à continuidade de seus negócios e na avaliação (*score*) dos riscos. Dessa forma, pode contribuir também com o planejamento e o direcionamento dos investimentos em *cybersecurity*.

A Figura “Incidentes reportados ao CERT.br – janeiro a dezembro de 2022” apresenta os 665.079 incidentes reportados ao CERT.br no período mencionado, separados por tipo de fraude.

Incidentes Reportados ao CERT.br - Janeiro a Dezembro de 2020

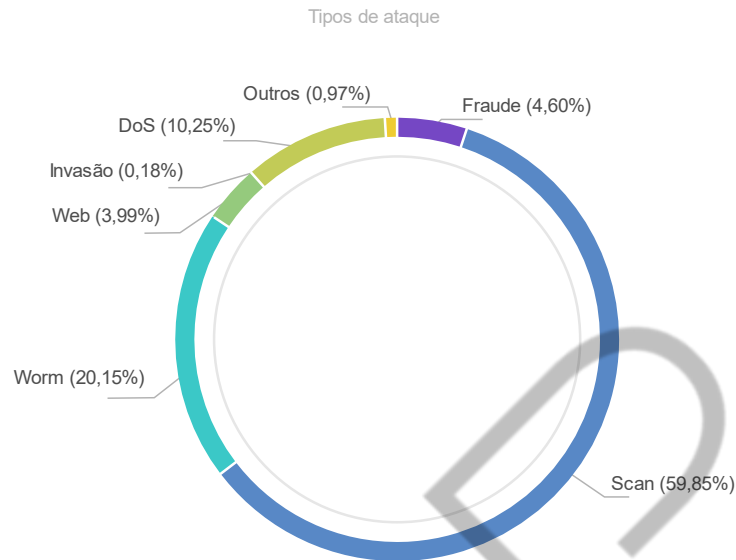


Figura 1 – Incidentes reportados ao CERT.br – janeiro a dezembro de 2022
Fonte: CERT.BR (2020)

Como estamos no começo de nossos estudos, talvez alguns desses tipos de ataques cibernéticos não sejam tão familiares assim para você. Não tem problema! Segue uma breve descrição de cada um deles, firmando um compromisso aqui de aprofundá-los ao longo de nosso curso:

- **Worm:** semelhante a um vírus, trata-se de um programa malicioso com a capacidade de se autorreplicar e infectar outros computadores, propagando-se de forma automática pela rede.
- **DoS (Denial of Service):** são ataques de negação de serviço, da qual o atacante utiliza um computador ou um conjunto de computadores para tirar de operação um serviço, um computador ou uma rede, enviando mais requisições e pacotes de rede fraudulentos, soterrando a máquina que não tem condições de atender a todos os pedidos.
- **Invasão:** um ataque bem-sucedido, cujo resultado é o ganho de acesso não autorizado a um computador ou rede, o que pode acontecer de várias maneiras, entre elas a exploração de uma falha de segurança de um serviço de rede desatualizado (*exploit*).

- **Web:** trata-se de caso particular de ataque, que visa especificamente o comprometimento de servidores Web ou mesmo o *defacement*, que é a desfigurações ou pichações de páginas na Internet.
- **Scan:** também chamado de *Port Scan*, trata-se de varreduras em redes de computadores com o objetivo de descobrir quais computadores estão ativos e quais serviços de rede estão sendo disponibilizados pelos mesmos, com versões de software. É largamente utilizado por atacantes e é considerado o primeiro passo de um ataque cibernético, pois por meio dele é possível “mapear o terreno” e identificar potenciais alvos, associando a eles possíveis vulnerabilidades aos serviços habilitados em um computador.
- **Fraude:** de acordo com *Houaiss*, é “qualquer ato ardiloso, enganoso, de má-fé, com o objetivo de lesar ou ludibriar outrem, ou de não cumprir determinado dever; logro”. Enquadram-se aqui as tentativas de fraudes, ou seja, de incidentes em que ocorre uma tentativa de obter algum tipo de vantagem.
- **Outros:** além dos mencionados, são incidentes que não se enquadrariam nas categorias mencionadas acima.

Entre os ataques de maior repercussão no ano de 2017, há que se destacar dois ataques de proporções mundiais: o WannaCry e o Petya.

Em 12 de maio de 2017, 74 países, entre eles, o Brasil, foram afetados pelo WannaCry (ver Figura “Tela do WannaCry”), um tipo de *ransomware* autopropagável capaz de criptografar os arquivos dos sistemas afetados.



Figura 2 – Tela do WannaCry
Fonte: Google Imagens (2017)

O WannaCry adicionou a extensão .WCRY aos arquivos infectados, exigindo um resgate de US\$ 300 ou \$ 600 (em bitcoins) para decodificá-los, estimando-se que os prejuízos globais tenham chegado a US\$ 1 bilhão.

Diferentemente da maioria dos *ransomwares*, ele não se propaga por intermédio de spam, mas explora uma vulnerabilidade no protocolo do *Server Message Block* (SMB) da Microsoft conhecida como *EternalBlue*, um dos protocolos fundamentais nas redes corporativas que fazem uso de servidores Windows (ou seja, a grande maioria das empresas).

O WannaCry explora uma vulnerabilidade do SMBv.1, protocolo que, diante disso, deveria ser imediatamente abandonado pelos usuários tanto das versões do Windows destinadas a servidores quanto das versões voltadas a desktops (vide Figura “Tela de recursos do Windows”), conforme alertado por Ned Pyle (Microsoft) em setembro de 2016. Por se tratar de uma versão obsoleta do protocolo, na maioria dos casos esse suporte pode ser desabilitado dos servidores Windows da empresa sem prejuízos para seus processos de trabalho.

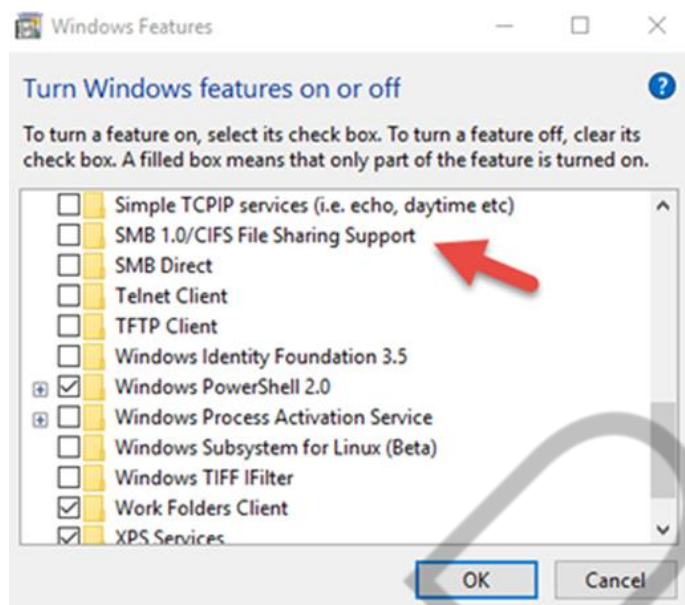


Figura 3 – Tela de recursos do Windows
Fonte: Blog Technet – Microsoft (2017)

Após a ampla contaminação, várias empresas e órgãos governamentais, tais como o Serviço Nacional de Saúde do Reino Unido, a Telefónica, o Tribunal de Justiça e o Ministério Público de São Paulo foram paralisados. E uma atualização foi disponibilizada pela Microsoft, em regime de urgência, aos usuários do sistema operacional Windows.

Em sua versão inicial, o Petya difere dos *ransomware* mais tradicionais na medida em que, em vez de criptografar arquivos um a um, ele impede completamente o acesso ao sistema, atacando estruturas de baixo nível do disco. Ao se inserir entre a BIOS (que é o *firmware*, uma porção de código que permite a inicialização do hardware e a chamada do sistema operacional) e o próprio sistema operacional da máquina, o Petya possui acesso aos recursos mais próximos da infraestrutura, possibilitando a criptografia do disco rígido inteiro.

BIOS, hardware, disco rígido? Como pode ver, conhecimentos sobre **Arquitetura de Computadores** serão fundamentais daqui para a frente, portanto, não deixe de conferir o capítulo desta fase chamado “Coração de silício”, combinado?

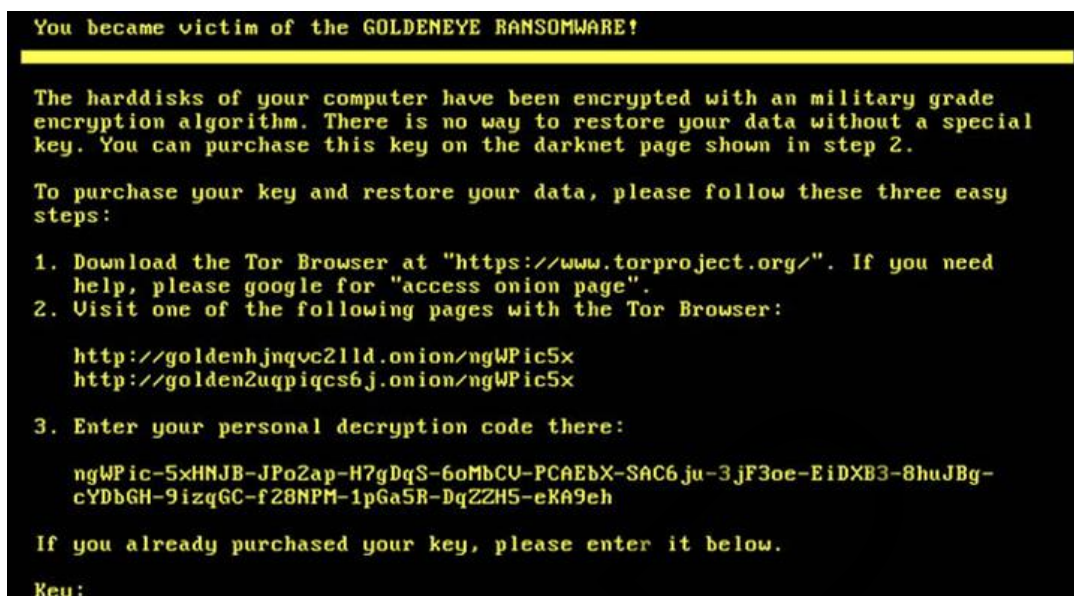


Figura 4 – Tela de aviso do GOLDENEYE
 Fonte: Blog Malwarebytes (2017)

4 VETORES DE ATAQUES

Simplificadamente, um vetor de ataque pode ser descrito como o meio utilizado pelo agente da ameaça para atacar o sistema-alvo.

O *website* HACKMAGEDDON, especializado em *timelines* e estatísticas em segurança cibernética, publicou os seguintes números referentes às técnicas de ataque de maior destaque em julho, agosto e setembro de 2023:

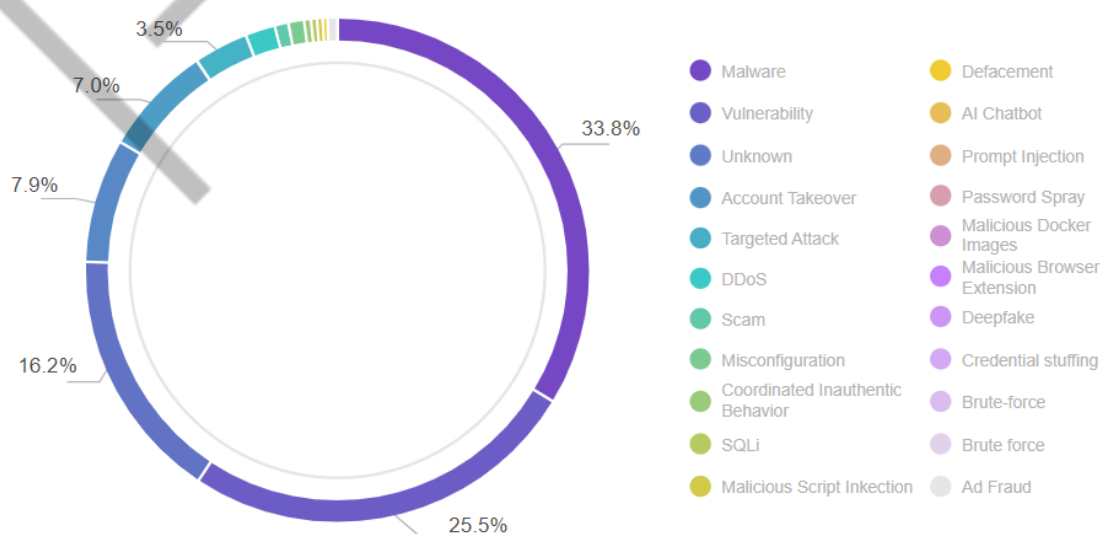


Figura 5 – Técnicas de ataque
 Fonte: PASSERI (2023)

Pode-se observar no gráfico que os vetores de ataque mais evidentes são os *Malwares /PoS Malwares* (33,8%).

Essencialmente, *Point-of-Sale malwares* constituem uma família específica de códigos maliciosos, cujo principal objetivo é a obtenção de informações relacionadas a transações financeiras, incluindo dados de cartões de crédito.

Para mais detalhes, acesse:

[<https://www.kaspersky.com.br/blog/malware-pos-e-raspadores-de-ram/2101/>](https://www.kaspersky.com.br/blog/malware-pos-e-raspadores-de-ram/2101/)

Também temos o *Accounting Takeover*, com 7,9%, que consiste, em linhas gerais, das ações de um atacante com o objetivo de obter as credenciais de um usuário legítimo (por exemplo, *username* e senha de uma conta de e-mail ou computador) para a execução de atividades não autorizadas. Os propósitos podem ser os mais distintos: acesso aos perfis de redes sociais da vítima, sistemas de correio eletrônico (que pode ser utilizado para recuperar a senha da vítima em outros serviços, ampliando o estrago), sistemas bancários eletrônicos, entre vários outros.

Os ataques direcionados (*Targeted Attacks*) também aparecem (7 %) e constituem, basicamente, de ataques dirigidos a alvos específicos, como, por exemplo, uma dada instituição ou entidade.

Logo, pode-se concluir que, a partir de análises estatísticas adequadas a cada contexto, é possível identificar apropriadamente os principais vetores de ataque utilizados contra um alvo e, dessa forma, contribuir para o desenvolvimento de estratégias e contramedidas de segurança, não apenas efetivas, mas também aderentes às necessidades de negócio.

5 MOTIVAÇÃO DOS ATAQUES E O ENQUADRAMENTO JURÍDICO

Não obstante, também a identificação da motivação dos ataques é de grande importância, dentre outras razões, dada a necessidade de mitigação dos riscos aos quais um alvo poderá vir a ser exposto. Além disso, ainda há a necessidade de constante aprimoramento das políticas de segurança da informação vigentes, no caso dos ambientes corporativos.

No gráfico da Figura “Motivações de ataque”, são identificados os principais motivadores dos ataques observados julho, agosto e setembro de 2023.

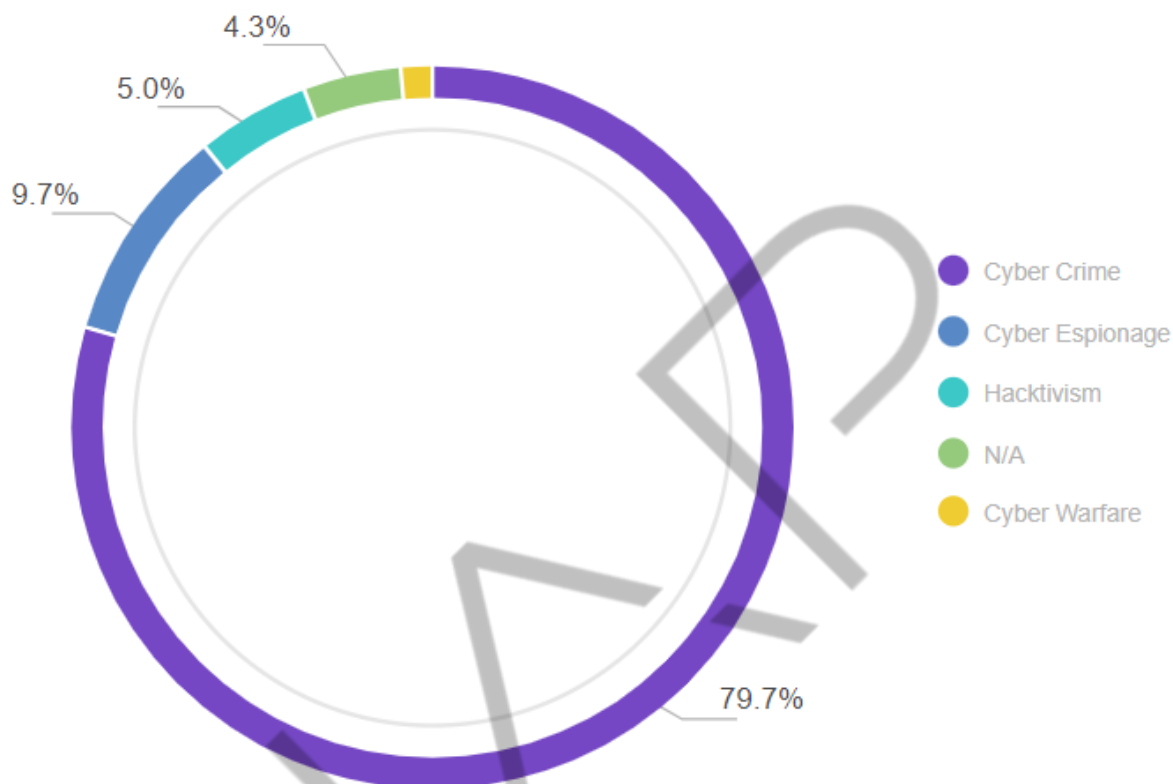


Figura 6 – Motivações de ataque
Fonte: PASSERI (2023)

Desse gráfico (Figura “Motivações de ataque”), observa-se que 79,7% dos ataques registrados tiveram como motivação a prática de cybercrimes, ou seja, quando sistemas ou recursos informáticos são utilizados como meio, ou alvo, para a prática de condutas antijurídicas, tendo-se o uso de *ransomwares* como um exemplo de uma das mais disseminadas dessas práticas.

Especialistas afirmam haver, ao menos, três crimes envolvidos em um ataque por *ransomware*: extorsão (Art. 158, Decreto-Lei n. 2.848 – 07/12/1940), crime de ameaça (Art. 147, Decreto-Lei n. 2.848 – 07/12/1940) e, no caso de um indivíduo, o delito de invasão de dispositivo informático (Art. 154-A, Lei n. 12.737 – 20/12/2012).

Hacktivism é o ato de “piratear”, ou invadir, um sistema informático por motivos políticos ou sociais. O hacktivista utiliza as mesmas técnicas e ferramentas de um *hacker*, porém, com a finalidade de interromper serviços e chamar a atenção para uma

causa política ou social (Figura “Ataque aos sites do governo do Ceará pedem anulação de votos da região Nordeste”).



Figura 7 – Ataque aos sites do governo do Ceará pedem anulação de votos da região Nordeste
Fonte: G1 CE (2022)

Por exemplo, um hacktivista poderia deixar uma mensagem bem visível em um *website* com grande volume de acessos e que defenda algum ponto de vista do qual o site diverge; ou ainda, poderia lançar um ataque de negação de serviço (*denial of service* – DoS) contra esse *website* a fim de tirá-lo do ar, caso ele não se retratasse em relação a esse ponto de vista.



Figura 8 – Ataque DDoS derruba a internet
Fonte: Blasting News (2016)

Mesmo motivado por diferentes razões, os resultados práticos das ações do hacktivista seriam os mesmos: na primeira hipótese, a desfiguração do website (*defacement*); e, na segunda, a indisponibilidade dele (DoS).

Em função das circunstâncias sob as quais tais ações foram praticadas, diferentes dispositivos previstos na legislação brasileira poderão ser aplicados para fins de encaminhamento e tratativa legal dessas ações.

Nesse aspecto, vale destacar as palavras do ex-ministro Sepúlveda Pertence – Primeira Turma, julgado em 22/09/1998: “[...] a invenção da pólvora não reclamou redefinição do homicídio para tornar explícito que nela se compreendia a morte dada a outrem mediante arma de fogo...”, o que significa dizer, de forma bem simplificada, que, mesmo sendo os crimes cibernéticos posteriores à edição de maior parte da lei, esta ainda pode ser aplicável para julgá-los.

CONCLUSÃO

Os crimes digitais têm crescido de forma exponencial, afinal, as mesmas tecnologias que possibilitam às *startups* uma estabilidade sem precedentes, também

conferem aos criminosos digitais (e suas “*startups* do crime”) a possibilidade de aumentar seus ganhos com muito menos exposição do que qualquer crime tradicional.

O mercado tem respondido à altura, intensificando os investimentos em segurança de informação. Claro que ainda há muito a fazer, uma vez que boa parte das empresas no Brasil não tem qualquer plano de ação caso um incidente de segurança aconteça.

Devemos, no entanto, enxergar o cenário com otimismo: os investimentos nessa área estão aumentando, o que representa uma excelente oportunidade de negócio aos profissionais de mercado. No entanto, a especialização na área é uma tarefa árdua, requerendo milhares de horas de estudo e prática. Mas não será em vão, acredite.

REFERÊNCIAS

- BRASIL AMPLIA em cerca de 12% investimentos em segurança da informação. **IT FORUM 365**, 2018. Disponível em: <<https://itforum.com.br/noticias/brasil-amplia-em-cerca-de-12-investimentos-em-seguranca-da-informacao/>>. Acesso em: 11 dez. 2020.
- BRASIL, PAÍS DIGITAL. Gartner prevê crescimento de 14% nos gastos globais com segurança e gerenciamento de riscos em 2024. 05 out. 2023. Disponível em: <<https://brasilpaisdigital.com.br/gartner-preve-crescimento-de-14-nos-gastos-globais-com-seguranca-e-gerenciamento-de-riscos-em-2024/>>. Acesso em: 17 jan. 2024
- CERT.BR. **Incidentes Reportados ao CERT.br – janeiro a dezembro de 2020**. 2020. Disponível em: <<https://www.cert.br/stats/incidentes/2020-jan-dec/tipos-ataque.html>>. Acesso em: 19 dez. 2022.
- CERT.BR. **Sobre o CERT.br**. 2017. Disponível em: <<https://www.cert.br/sobre/>>. Acesso em: 11 dez. 2020.
- CRAIGEN, D.; DIAKUN-THIBAUT, N.; PURSE, R. Defining Cybersecurity. **Tim Review**, 2014. Disponível em: <https://timreview.ca/sites/default/files/article_PDF/Craigen_et_al_TIMReview_October2014.pdf>. Acesso em: 11 dez. 2020.
- DELOITTE. **Hacktivism: a defender's playbook**. 2016. Disponível em: <<https://www2.deloitte.com/content/dam/Deloitte/us/Documents/risk/us-aers-hacktivism.pdf>>. Acesso em: 11 dez. 2020.
- ENTENDA os ciberataques feitos pelo ransomware WannaCry na última sexta-feira (12). Canal Tech, 2017. Disponível em: <<https://canaltech.com.br/hacker/entenda-os-ciberataques-feitos-pelo-ransomware-wannacry-na-ultima-sexta-12-93724/>>. Acesso em: 11 dez. 2020.
- FERRARI, B. **Ransomware: o crime quase perfeito**. 2017. Disponível em: <<https://epoca.globo.com/tecnologia/experiencias-digitais/noticia/2017/03/ransomware-o-crime-quase-perfeito.html>>. Acesso em: 11 dez. 2020.
- FERREIRA, L. P. **Os “crimes de informática” no Direito Penal Brasileiro**. 2013. Disponível em: <<http://www.egov.ufsc.br/portal/conteudo/os-%E2%80%9Ccrimes-de-inform%C3%A1tica%E2%80%9D-no-direito-penal-brasileiro>>. Acesso em: 11 dez. 2020.
- G1 CE. Após ataque hacker, Governo de Ceará recupera sites do Estado. **G1 CE**, 13 dez. 2022. Disponível em: <<https://g1.globo.com/ce/ceara/noticia/2022/12/13/apos-ataque-hacker-governo-de-ceara-recupera-sites-do-estado.ghtml>>. Acesso em: 19 dez. 2022.
- PANCINI, L. 58% dos brasileiros sofreram crimes cibernéticos, aponta estudo da Norton. **Exame**, 11 mar. 2022. Disponível em: <<https://exame.com/tecnologia/58-dos-brasileiros-sofreram-crimes-ciberneticos-aponta-estudo-da-norton/>>. Acesso em: 19 dez. 2022.
- PASSERI, P. Q3 2023 Cyber Attacks Statistics. **Hackmageddon**, 5 dez. 2023. Disponível em: <<https://www.hackmageddon.com/2023/12/05/q3-2023-cyber-attacks-statistics/>>. Acesso em: 17 jan. 2023.
- RANSOM.WANNACRYCRYPT. Malwarebytes, [s.d.] Disponível em: <<https://blog.malwarebytes.com/detections/ransom-wannacrypt/>>. Acesso em: 11 dez. 2020.

ROVER, T. **Internet facilita crimes e dificulta investigação, estimulando a impunidade.** 2017. Disponível em: <<http://www.conjur.com.br/2017-fev-05/entrevista-daniel-burg-especialista-crimes-virtuais>>. Acesso em: 11 dez. 2020.

SORIMA NETO, J. **Brasil ganha espaço em segurança da informação.** 2017. Disponível em: <<https://oglobo.globo.com/economia/brasil-ganha-espaco-em-seguranca-da-informacao-17644315>>. Acesso em: 11 dez. 2020.

STAMAN, J. A. *et al.* **Cybersecurity issues and challenges:** in brief. 2016. Disponível em: <<https://fas.org/sgp/crs/misc/R43833.pdf>>. Acesso em: 11 dez. 2020.

TECHNET MICROSOFT. **Stop using SMB3.** 2016. Disponível em: <<https://blogs.technet.microsoft.com/filecab/2016/09/16/stop-using-smb1/>>. Acesso em: 11 dez. 2020.

EMASP